

Executive Summary

Il progetto e già ben impostato: Next.js App Router, struttura bilingue IT/EN, Supabase con RLS, area admin, area renter, richieste pubbliche, voucher/QR/check-in, sitemap e pagine SEO dedicate.

Priorità principali:

1. Beach Club non è ancora pienamente coerente lato database: nel codice esiste, ma nelle migrazioni resta boat-with-skipper e non è evidente una migrazione che inserisca beach_club.
2. Endpoint email pubblico abusabile: /api/booking-email può essere chiamato direttamente per inviare email via Resend se la key è configurata.
3. Voucher/check-in pubblici con codice prevedibile: i codici sono basati su timestamp, quindi non abbastanza robusti per una pagina pubblica che mostra dati cliente/pagamento.
4. Next.js va aggiornato: il progetto usa Next ^14.2.15; advisories ufficiali indicano fix successivi nella linea 14.2.x.

Stato generale progetto

- Struttura Next.js: buona. App Router, route chiare, componenti separati. Priorità media.
- Frontend pubblico: buono. Chiaro, bilingue, CTA presenti. Priorità media.
- SEO: medio. Metadata e JSON-LD ok, ma alcuni slug EN non coincidono con il brief. Priorità alta.
- Beach Club / skipper: fragile. Codice aggiornato, DB/migrazioni non allineate. Priorità alta.
- Backend/API: medio. Supabase RPC buone, email endpoint fragile. Priorità alta.
- Supabase/RLS: buono, ma da verificare con test ruoli anon/auth/renter/admin. Priorità alta.
- Area renter: media. Funzionale, ma tecnica e poco guidata. Priorità media.
- Area admin: buona. Operativa, ma mancano filtri/export/conferme robuste. Priorità media.
- Email/Resend: parziale. Custom fetch Resend, no PDF/attachments integrati. Priorità media.
- Sicurezza: media. Nessun service role evidente, ma rate limit assente. Priorità alta.
- Performance: media. Immagini spesso img, client components migliorabili. Priorità media.

Frontend pubblico

Cosa funziona:

- Brand coerente.
- CTA frequenti.
- Testi già spiegano richiesta non conferma.
- Pagine SEO ricche.

Problemi e soluzioni:

- Form richiesta lungo. Dove: BookingRequestModal.tsx. Impatto: attrito conversione. Priorità media. Soluzione: step form o campi progressivi.
- Modello marketplace da rinforzare. Dove: Home, landing, email. Impatto: cliente può

pensare che IschiaMotion sia noleggiatore diretto. Priorita media. Soluzione: trust copy vicino a ogni CTA.

- Poche prove sociali. Dove: homepage/landing. Impatto: fiducia limitata. Priorita media. Soluzione: recensioni, partner verified, badge locali.
- Mobile da verificare visivamente. Dove: CSS globale. Impatto: possibili overflow tabelle/card. Priorita media. Soluzione: QA Playwright mobile.
- Card/category UX delicata. Corpo card landing, bottone richiesta. Priorita bassa. Soluzione: mantenere distinzione visiva Scopri vs Verifica.

SEO

SEO tecnico:

- Metadata presenti su homepage e landing.
- Canonical e hreflang presenti tramite alternates.
- Sitemap e robots presenti.
- JSON-LD presente: WebSite, Organization, Service, FAQPage, BreadcrumbList, WebPage.

Problemi:

- Il brief cita slug EN come /en/ischia-scooter-rental, /en/ischia-car-rental, /en/ischia-boat-rental; il codice usa /en/scooter-rental-ischia, /en/car-rental-ischia, /en/boat-rental-ischia.
- Mancano redirect dagli alias attesi agli slug reali.
- Nessuna metadata Twitter card esplicita.
- Sitemap usa lastModified = new Date() a ogni generazione: puo sembrare che tutte le pagine cambino sempre.
- Admin/renter sono disallow in robots, ma non hanno noindex esplicito.

Quick win SEO:

- Aggiungere redirect alias EN verso slug reali.
- Aggiungere Twitter metadata.
- Stabilizzare lastModified o usare date reali.
- Aggiungere noindex a admin/renter/login/checkin se non devono indicizzare.

Opportunita keyword:

- IT: noleggio scooter ischia porto, noleggio auto ischia senza carta, beach club ischia lettini, noleggio gommone ischia senza patente.
- EN: scooter rental Ischia port, Ischia beach club booking, rubber dinghy rental Ischia, car rental Ischia ferry port.

Categoria Barca con skipper -> Beach Club

Dove compare oggi:

- Codice pubblico: Beach Club presente in VehicleFilters, HeroSearch, SearchResults, VehicleCard, category-landings, category-landing-paths.
- Pagine SEO: /it/beach-club-ischia e /en/ischia-beach-club presenti.
- Redirect: presenti in next.config.mjs da vecchi slug skipper.

- Sitemap: include Beach Club.
- Migrazioni: restano 0016_add_boat_with_skipper_category.sql, 0018_split_boat_and_rib_categories.sql e 0022_renter_category_delivery_capabilities.sql con boat-with-skipper.

Problema principale:

Non è evidente una migrazione che inserisca beach_club in vehicle_categories. Il codice può cercare Beach Club, ma il DB potrebbe non avere la categoria reale.

Intervento futuro consigliato:

- Creare migrazione DB per inserire beach_club.
- Disattivare o rinominare boat-with-skipper.
- Aggiornare RPC SQL togliendo boat-with-skipper dalle regole nautiche.
- Verificare seed/mock/veicoli reali con categoria beach_club.
- Mantenere redirect 301 dagli slug skipper.
- Verificare Search Console dopo redirect.

Priorità: alta.

Backend/API

- /api/booking-email: invia email admin e cliente. Problema: endpoint pubblico senza firma/rate limit. Rischio alto. Miglioria: token interno, firma HMAC o invio server-side post-RPC.
 - create_public_booking_request RPC: crea booking pubblico. Buona validazione date/disponibilità. Mancano limiti robusti lunghezze/email/telefono. Rischio medio.
 - search_public_vehicles RPC: ricerca pubblica. Buona sanitizzazione via RPC. Rischio basso.
- Da aggiornare per categoria Beach Club DB.
- auth/callback: conferma auth. Basic ok. Validare meglio next. Rischio basso.
 - Server actions admin: CRUD booking/vehicles/renters protetti da requireAdmin. Rischio medio. Aggiungere conferme per azioni critiche.
 - Server actions renter: disponibilità/prezzi/check-in. RLS protegge, ma form passa renterId. Rischio medio. Ricavare renterId solo dalla sessione.

Supabase/database

Tabelle dedotte:

profiles, renters, renter_users, vehicle_categories, pickup_points, vehicles, bookings, booking_vouchers, checkins, renter_category_availability, renter_delivery_capabilities, renter_category_delivery_capabilities, vehicle_availability_rules, vehicle_price_rules.

Cose buone:

- RLS abilitato su molte tabelle.
- Accesso pubblico booking diretto rimosso in 0023_lock_public_booking_insert.sql.
- Admin/renter separati tramite is_admin(), is_renter(), current_renter_ids().
- Storage immagini limitato ad admin per upload.

Rischi:

- boat-with-skipper ancora attivo nelle migrazioni.
- beach_club non seminato via migrazione.
- Voucher pubblico espone dati se il codice è conosciuto.
- Funzioni security definer da testare periodicamente con ruoli anon/auth/renter/admin.

Area renter

Funziona:

- Login/register.
- Approvazione admin.
- Prenotazioni assegnate.
- Disponibilita categoria.
- Disponibilita calendario mezzi.
- Prezzi stagionali.
- Check-in.

Manca o è fragile:

- UX molto tecnica per partner non digitali.
- Nessun onboarding guidato.
- Nessun riepilogo cosa devo fare oggi.
- Tabelle potenzialmente pesanti su mobile.
- Partner non può gestire anagrafica mezzi completa, solo disponibilita/prezzi.
- Renter vede clienti abbreviati: buono per privacy, ma potrebbe mancare telefono operativo se deve consegnare.

Area admin

Funziona:

- Dashboard.
- Booking.
- Renter approval/reject/disable.
- Veicoli.
- Prezzi stagionali.
- Voucher.
- Check-in.
- Pagamenti manuali.

Migliorie operative:

- Filtri booking per stato/data/categoria/renter.
- Ricerca globale booking.
- Export CSV.
- Timeline eventi booking.
- Conferme più forti per disattivazioni e cancellazioni regole.
- Log audit admin: chi ha cambiato cosa e quando.
- Vista oggi/domani per consegne/ritiri.

Email/Resend

Stato:

- .env.example prevede RESEND_API_KEY, BOOKING_ADMIN_EMAIL, BOOKING_FROM_EMAIL.
- package.json non installa resend; il progetto usa una classe custom con fetch verso Resend.

- Email admin e cliente sono generate in /api/booking-email.

PDF audit:

- Tecnicamente possibile usando API Resend con attachment base64.
- Serve dominio mittente verificato, SPF/DKIM/DMARC corretti.
- Endpoint attuale non gestisce allegati PDF, quindi l'invio PDF richiede script o sviluppo dedicato.

Performance

Problemi:

- Molte immagini usano img invece di next/image.
- Tabelle admin/renter possono diventare lente senza paginazione.
- Nessuna evidenza di loading/error boundary dedicati.
- Client surface della home migliorabile.

Azioni consigliate:

- Migrare immagini pubbliche principali a next/image.
- Paginare booking/admin/renter.
- Aggiungere skeleton/loading.
- Separare parti statiche e interattive homepage.
- Usare caching mirato per pickup/category prices.

Sicurezza

- Email endpoint abusabile. Dove: /api/booking-email. Gravita alta. Soluzione: firma HMAC/internal token/rate limit.
- Voucher prevedibile. Dove: buildVoucherCode(). Gravita alta. Soluzione: codici random lunghi, scadenza, rate limit.
- Rate limiting assente. Dove: form, email, register. Gravita alta. Soluzione: Upstash/Vercel firewall/Supabase edge guard.
- Next.js non aggiornato. Dove: package.json. Gravita alta. Soluzione: aggiornare almeno a patched 14.2.x.
- Beach Club DB non allineato. Dove: migrazioni. Gravita alta. Soluzione: migrazione dedicata.
- CSRF server actions. Dove: admin/renter actions. Gravita media. Soluzione: CSRF token o double-submit.
- Input poco limitati. Dove: booking/email/forms. Gravita media. Soluzione: schema validation e limiti lunghezza.
- Public voucher dati pagamento. Dove: /checkin/[code]. Gravita medio/alta. Soluzione:

minimizzare dati pubblici.

- Form renter registra spam. Dove: /renter/register. Gravita media. Soluzione: captcha o throttling.

Roadmap consigliata

Fase 1 - Urgente:

- Aggiornare Next.js a release patchata.
- Proteggere /api/booking-email.
- Rendere voucher code random e non prevedibili.
- Creare migrazione Beach Club e disattivare/redirectare boat-with-skipper.

Fase 2 - SEO e conversione:

- Redirect alias EN richiesti dal brief.
- Aggiungere Twitter metadata.
- Rafforzare trust/reviews/partner verification.
- Rendere form richiesta piu breve o progressivo.
- Aggiungere pagine SEO porto, Forio, Casamicciola, senza patente dove corretto.

Fase 3 - Admin/Renter operativo:

- Filtri, search, export admin.
- Dashboard renter azioni di oggi.
- Audit log admin.
- Conferme robuste per azioni critiche.

Fase 4 - Scalabilita:

- Paginazione server.
- Event timeline booking.
- Email template strutturati.
- PDF/voucher automatico.
- Monitoring errori e analytics conversioni.

Checklist pronta per sviluppo

- [] Aggiornare Next.js a release patchata.
- [] Aggiungere rate limit a booking, renter register, email route.
- [] Proteggere /api/booking-email con firma interna.
- [] Generare booking/voucher code random non timestamp.
- [] Migrazione beach_club in Supabase.
- [] Disattivare o rinominare boat-with-skipper nel DB.
- [] Aggiornare RPC SQL per togliere boat-with-skipper.
- [] Aggiungere redirect alias EN SEO.
- [] Aggiungere noindex per admin/renter/checkin se necessario.
- [] Migrare immagini principali a next/image.
- [] Aggiungere filtri admin booking.
- [] Aggiungere export CSV admin.

- ☐ Aggiungere audit log admin.
- ☐ Semplificare form pubblico.
- ☐ Aggiungere trust signals e recensioni.
- ☐ Preparare endpoint PDF/email solo dopo hardening email.

Validazione eseguita: pnpm lint ok.